are only allowed to read their own messages and not those of anybody else, or that they can only send messages to users in their friendship group.

There are two primary approaches to access control that are used for APIs:

- *Identity-based access control* first identifies the user and then determines what they can do based on who they are. A user can try to access any resource but may be denied access based on access control rules.
- *Capability-based access control instead uses special tokens or keys known as capabilities to access an API. The capability itself says what operations the bearer can perform rather than who the user is.* A capability both names a resource and describes the permissions on it, so a user is not able to access any resource that they do not have a capability for.

We will cover both access control methods in detail throughout the book.

Capability-based security

The predominant approach to access control is identity-based, where who you are determines what you can do. When you run an application on your computer, it runs with the same permissions that you have. It can read and write all the files that you can read and write and perform all the same actions that you can do. In a capability-based system, permissions are based on unforgeable references known as capabilities (or keys). A user or an application can only read a file if they hold a capability that allows them to read that specific file. This is a bit like a physical key that you use in the real world; whoever holds the key can open the door that it unlocks. Just like a real key typically only unlocks a single door, capabilities are typically also restricted to just one object or file. A user may need many capabilities to get their work done, and capability systems provide mechanisms for managing all these capabilities in a user-friendly way.